报告1：数据治理、安全、隐私、伦理与新兴治理技术的论证和验证

项目：面向多商家电商平台的订单履约数据整合与质量治理系统设计（INT6164）
作者身份：组员C，负责数据质量、元数据、血缘、可观测性规则及安全隐私
数据：Olist Brazilian E-Commerce Public Dataset，附件archive中的9个CSV
验证日期：2026年11月9日；主结果批次：batch_20261109_223909
交付形态：Markdown正文、可编辑Word、SQL/Python脚本、HTML/CSV目录及真实运行证据

摘要

本报告把治理视为“数据是否适合使用、使用条件能否解释、出现问题能否追查”的共同机制，而非仅在数据库建表后补一份制度说明。围绕已有MySQL项目，C在A数据字典和代码基础上定义45条规则，对1550922条源记录实际运行检查，建立72字段元数据目录、一条可逐单追溯的延迟天数血缘、批次级检查与观察结果，并以明确标注的合成数据进行故障注入。全量45条规则中23条PASS、22条WARN；两个全量批次异常计数一致。7项治理测试通过、19项角色权限用例符合预期，同时实际揭示可回滚审计、残余准标识符风险、凭据暴露与非原子发布等限制。因此结论不是“原型已经全面安全”，而是已经形成可检查的治理闭环，并能够解释其尚未覆盖的风险。

1. 场景、角色与证据边界

订单履约详情和延迟筛选依赖订单、明细、支付、客户和卖家正确关联。主外键保证写入完整性，却不能独自识别条件缺失、业务状态矛盾、指标口径冲突和未经约束的历史问题。尤其是核心表拒绝的重复键若未先保留原始输入，导入失败后将难以解释“哪一条记录为何没有进入页面”。

A负责表与字段含义、模型和业务查询；C负责质量规则、检查结果、异常处置、元数据和血缘；B负责运行批次采集及页面接入。C为验证独立写入与B同结构的processing_log，不代表B原型页面已接入。未修改附件MYSQL和archive原文件；交付包复用其DOCS、SQL、SRC、TESTS、EVIDENCE组织方式，新增C负责的治理对象。

数据质量结论基于本机MySQL 8.0.46、Python 3.15.0rc1的实际运行。权限方案采用现有root进行本地初始化和验证，六个临时账号逐一登录测试后删除；这不证明已使用最小权限运行账号完成整条流水线。技术机制分为已实现、已验证、设计待实施三种状态，报告始终按此区分。

2. 治理原则与生命周期

本项目采取目的限定、最小化使用、来源可解释、质量透明和责任明确五项原则。原始CSV只读保留；暂存层记录源文件、数据记录序号和batch_id；规则检查在暂存层进行；异常标记或隔离后进入核心表；查询层展示指标及质量标识；运行和访问结果进入独立日志。教学目的不需要客户持久ID、电话或外部网址出现在普通管理页面。

业务时间与处理时间必须分离。archive实际下单时间范围为2016-09-04 21:15:19至2018-10-17 17:30:18，而本次导入发生于2026-11-09。前者说明历史交易发生时间，后者说明本次处理时效和状态。将旧订单日期当作“最近导入时间”会制造错误时效告警；反过来用2026年处理日期补齐2017年签收会制造虚假的履约延迟。

保留期也是治理成本的一部分。建议课程评分和申诉期内保留必要证据，敏感原文和隔离负载采用经组长确认的复核删除期（例如90天），删除覆盖备份副本。当前并未实施自动删除和备份恢复验证，不应把建议周期写成已执行事实。

3. 数据质量：从数据库约束扩展到用途规则

45条规则由同一rules.py定义，流水线执行与清单/SQL导出共享这一来源，减少正文与代码口径漂移。分类为重复键8、关联失败11、条件缺失7、时间顺序8、域值范围9、一致性1、口径1。每条规则有检查分母、异常率阈值、严重程度、处置动作、业务影响及样例。0异常为PASS；有异常且不超过阈值为WARN；超过阈值为FAIL。阈值是首次画像的课堂初始值，不是长期验证过的业务SLA。

发现	实际数量	查询/指标影响	处置与判断
评价review_id主键冲突后续记录	814	不处理会导入失败，静默去重会丢评价	隔离保存负载；A复核联合主键方案
地理表邮编前缀多坐标的后续记录	981148	原始关联放大行数	聚合成19015前缀；不是98%数据损坏
订单没有明细 / 没有支付	775 / 1	INNER JOIN丢订单、缺失显示0可能误解	保留主订单并标记
delivered缺签收 / 缺批准	8 / 14	延迟和处理时长不可计算	标记，披露有效分母
非delivered却有签收	6	不限状态会多计延迟	标记，不自动改业务状态
交承运早于下单 / 早于批准	166 / 1359	出现负处理时长	保留并提示，等待上游核验
签收早于交承运	23	履约时间可信度降低	标记，不交换日期
订单支付与商品加运费差额>1.00	249	对账不一致	分表预聚合后核验，原因未证实

所有前向外键检查为0异常并不等于数据完整：反向缺明细、条件性日期缺失和模型主键不一致仍存在。规则命中数不能相加作为总异常订单数，因为同一订单可能命中多个条件。

处置遵循可逆和可解释原则。隔离行保存原始JSON和原因；标记保留业务值；修正必须有确定转换。评价隔离后99224 814=98410行，非空评价从原始40977条降为核心40641条，报告必须披露覆盖变化。geo平均坐标会受完全重复行和极值影响；城市/州取首行是原型近似，替代方案是保留多坐标原表并使用权威邮编维表或去重中位数。

4. 元数据与血缘：治理不能只写在正文

元数据目录包括50个核心业务字段、18个系统字段、4个派生字段，合计72个字段、11张表/视图。字段语义基于A文档，类型/键/可空性取实际information_schema；C补充源文件/字段、转换、质量要求、规则编号、敏感级别、职责及本批空值率/去重数。HTML支持搜索和表/敏感级别筛选，CSV适合Excel或工具导入，metadata_catalog表适合B页面查询。

目录揭示了文档和DDL的不一致，例如A字典规定下单时间不可空，但现有orders DDL允许NULL；C并未偷偷修改A模型，而用NUL-06拦截源关键缺失，并在目录中同时记录“实际结构”和“质量要求”。translation源有71行，A未建对应核心表，本交付只将它暂存用于品类关联检查；目录不是擅自新增A业务模型的证明。

延迟天数血缘包含原文件、记录、暂存、规则、核心字段、DATEDIFF和可查看结果。实测订单01cbdb2a8c075eaf248af643b3389f73：源第9914条数据记录，预计2017-08-09 00:00:00，签收2017-08-24 23:18:12，状态delivered，视图返回15天。页面字段的错误可以据此回溯到原始记录，而不只得到“指标来自orders表”的粗粒度解释。

5. 安全：最小权限与审计的实测边界

安全方案使用角色、受限视图和审计入口过程。客服只调用订单点查过程；商家按数据库账号到seller_id映射仅看本卖家；管理者读取州级汇总及治理结果；C治理角色业务只读、治理结果可更新；审计员只读日志。完整矩阵与SQL见security_privacy_plan.md和07_security_roles.sql。MySQL角色必须在登录时激活，不能只GRANT后假定有效[3]。

19项用例验证了允许与拒绝的边界：商家看到2033行且仅一个映射卖家；客服不能绕过程直接读视图/客户表；治理角色不能DELETE业务或审计日志；审计员不能读订单明细。客服自动提交查询使访问日志1→2，记录实际账号、订单、时间和返回数。

但额外反例同样重要：显式事务内CALL后ROLLBACK撤销日志，查询成功而日志2→2。因此所谓“只能经过程访问”只是入口约束，不是不可撤销审计。general_log=OFF且未安装audit_log，全库访问日志未覆盖；MySQL Enterprise Audit为商业企业版扩展，不能默认宣称社区原型已有该能力[4]。生产需独立追加式日志通道、限制删除、完整身份关联和定期审查。

实测还发现require_secure_transport=OFF，虽然服务器支持TLS但未强制；MYSQL内两处JSON含明文root凭据，README声称的.gitignore实际不存在。C交付只使用环境变量密码，不复制凭据，但尚未替A/B轮换凭据或改服务器设置。TLS、静态加密、密码锁定边界、备份恢复和OS权限均属待验证内容。

6. 隐私：公开与哈希不是充分保护

发布者称数据已匿名化且店铺/合作伙伴文本用《权力的游戏》家族名替换，但这不等于所有消费者个人信息均消失[1]。customer_unique_id是跨订单持久标识，可串联个人行为；邮编与城市是准标识符；评论含自由文本。

实际核心40641条非空评论中正则命中电话2条、网址2条，脱敏视图同正则残留0。原文邮箱和CPF命中0，缺少正样本，所以不能证明邮箱/CPF规则有效，更不能证明姓名、地址和其他格式均被检测。外部报告只展示[PHONE]/[URL]替换后的样例，不披露电话号码。

k评估中，k为组内不同customer_unique_id数量，比例分母为99441条客户表记录。原始邮编5位+城市+州有18.99%记录处在k<5分组；客服视图仍保留城市，实际邮编3位+城市+州组合降至5.39%，不是先前仅用邮编3位+州算出的0.06%。去掉城市属于进一步设计对照。仅州时没有k<5分组，但仍不能据此认证匿名，因为加入时间、金额、外部背景知识或多次发布可能再次缩小人群。

因此建议按角色删减字段、禁止外部重新识别、评论导出默认关闭，必要时以HMAC替代稳定标识并隔离密钥。HMAC、查询预算和完整文本敏感信息识别尚未部署；不要把技术术语当作已完成验证。

7. 伦理与数据使用限制

按日期天数口径，AL州延迟率21.41%（85/397），SP州4.49%（1820/40494）。这种差异只是描述性结果，不是地域导致延迟或商家过失的因果证明。距离、承运商、品类、节假日与样本量均可能混杂；RR仅41笔有效订单，更不宜据小样本平均做强结论。

数据质量处理也有伦理代价。隔离评价改变覆盖率；排除缺签收订单可能改变延迟率；忽略复杂支付和运费会错误评价商家；一单多卖家时订单级签收不能自动归责到某个卖家。应报告分母、缺失、隔离、标记和候选口径，并保留人工复核、业务解释和争议渠道。

Kaggle核验许可为CC BY-NC-SA 4.0：署名、非商业、改编分享遵循相同许可[1][2]。这不是“任意使用”的授权；隐私/人格权等其他权利仍可能限制使用。课堂报告注明来源，不发布原始CSV；合成TEST_GOV_数据与真实数据分库，禁止假称真实业务结果。许可核查不等于完整法律合规认证。

8. 新兴治理技术：采用价值、维护成本、局限与替代

“新兴”不是为作业安装尽可能多平台，而是让目录、质量、血缘和运行信息形成机器可消费的关联。传统数据字典只解释字段；主动元数据和数据契约进一步让字段变更、质量异常和指标影响可被持续观察。本项目实现轻量基础，未把概念论证冒充大型平台部署。

技术/机制	本项目状态与价值	维护成本/局限	替代或升级
元数据目录与主动元数据	HTML/CSV/表已可查看；字段关联规则和批次画像	72字段需随A改DDL维护；当前非自动发现所有变化	小规模CSV/Markdown；规模扩大用OpenMetadata/DataHub等统一目录
数据契约/规则即代码	45条规则与表头检查可执行，同源导出清单	阈值需审批；语义变更和键标准化仍可能漏检；未采用专用契约schema	数据库约束+人工核对；未来使用版本化契约与CI门禁
字段与记录级血缘	15天真实样例可回到CSV记录和批次	暂存覆盖、非并发、历史原文不版本化	手工血缘表适合当前；未来不可变批次快照+运行时采集
OpenLineage风格事件	输出run/job/dataset/columnLineage JSON便于未来互操作	未schema完整校验；自定义schema地址占位；未接接收端	当前表/CSV足够；接口验证后再对接标准平台
数据可观测性	行数守恒、状态、质量、指标变化按batch_id关联	只能运行时检查；无告警推送/独立探针；SLA未成熟	小作业SQL日志；更大规模再接调度器/监控平台
自动文本脱敏与k评估	已发现电话与稀疏准标识符	正则漏姓名地址；k不防背景知识；再识别没有完整测评	最小化字段优先；高风险文本可隔离或人工审查
差分隐私/智能异常检测	仅技术论证，未实施	隐私预算/小样本误差或训练漂移成本；机器模型难解释	课堂确定性规则和小单元格抑制更可控

DCAT 3强调Web数据目录互操作[5]，但本项目列级目录不是DCAT RDF实现。OpenLineage定义Job、Run、Dataset和可扩展facets[6]；本地JSON只是对这一模型的原型表达，不能声称已标准认证。平台化升级只有在更多数据源、团队或变更频率使手工维护成本明显上升时才合理。

9. 异常验证与成本证据

合成测试A固定预期后运行：45条规则异常数与记录键均一致，其中36条实际正向触发，9条为0用来验证无误报。重复订单/明细/支付、孤立外键、缺签收、负价格、非法状态/日期、时间矛盾、口径冲突均触发。A测试核心orders14 3=11，明细16 6=10，支付15 4=11，评价8 3=5；不存在被隔离009/014和负价格明细。B缺文件失败未构建核心，行数保持A；C订单14→7触发 50%行数告警。7项pytest通过。

两个全量批次各产生完整规则汇总和批次证据；首次处理日志跨度83秒（外部墙钟约84秒），不能据此断言跨硬件性能SLA。规则检查本身约22秒，源暂存尤其geo占主要输入量；每规则最多1000条异常明细降低日志体积，但完整计数留在汇总。geo保留约百万行暂存、约19015行核心；历史隔离和结果追加增长，需要清理策略。人工成本主要是A语义核验、C阈值和规则升级、B调度/页面集成，以及权限/隐私复核；没有测得人时，不能虚构维护工时。

10. 结论与未完成验证

最低标准已落实到文件与运行证据：可查看目录、完整核心指标血缘、每批质量结果、一次以上异常测试及记录，以及价值/成本/局限/替代方案正文。已发现原文个人信息、指标口径冲突和模型适配问题，比单纯声称“数据已清洗”更有治理价值。

仍需A/组长确认延迟口径与评价主键，B接入真实页面与稳定发布；专用账号端到端运行、构建中失败回滚、历史批次原文快照、不可回滚审计、独立时效探测、TLS/备份恢复和更完整隐私识别尚未验证。本原型是可复现的课堂治理验证包，不是可直接承诺生产合规的系统。

参考与证据

[1] Olist数据集及CC BY-NC-SA 4.0许可标注。
[2] CC BY-NC-SA 4.0中文许可摘要。
[3] MySQL 8.0角色机制。
[4] MySQL Enterprise Audit。
[5] W3C DCAT 3 Recommendation。
[6] OpenLineage对象模型。

本地依据：A附件DOCS/DATA_MODEL/data_dictionary.md、lineage_info.md、SQL/create_tables.sql.sql；本交付DOCS/GOVERNANCE/quality_report.md、quality_rules.md、metadata_catalog.html、lineage_delay_days.md、observability_rules.md、security_privacy_plan.md；EVIDENCE/governance_test_evidence.md、security_verification_record.md、source_manifest.csv、run_outputs/verified_facts.json。网页许可与技术说明核查于2026-11-09。